

Business Impact Analysis

A Business Impact Analysis evaluates the severity and operational impact of vulnerabilities identified on target host 192.168.1.165 (Metasploitable2).

Executive Summary

The target system represents an extreme operational risk to the organization. Multiple critical vulnerabilities including a built-in FTP backdoor, remote code execution via PHP CGI, unauthenticated SMB null sessions, and default system credentials allow unauthenticated attackers to obtain full administrative control within seconds.

Threat Landscape & Vulnerability Profile

Critical Remote Code Execution (RCE) Vectors:

- **vsFTPD 2.3.4 Backdoor (Port 21):** Contains a known backdoor trigger allowing direct execution to a root shell. Penetration testing confirmed immediate root access and full directory traversal (`/root`, `/etc/shadow`).
- **PHP CGI Argument Injection (Port 80):** Exploitation of CVE-2012-1823 via `phpMyAdmin` allowed an attacker to spawn a reverse shell as `www-data`.

Weak Authentication & Credential Exposure:

- **Default Credentials (SSH/FTP):** Valid login via `msfadmin:msfadmin` provided interactive SSH shell access. The user `msfadmin` possesses full `sudo` rights without restrictions (`ALL`).
- **Anonymous Access:** Port 21 permits `anonymous:anonymous` access.
- **Password Hash Exposure:** Root shell access directly compromised `/etc/shadow`, exposing password hashes for system users including `root`, `postgres`, `sys`, and `msfadmin`.

Insecure Storage & File System Permissiveness:

- ◆ **Writable SMB Shares:** SMB network shares `/tmp` and `/msfadmin` grant full READ/WRITE permissions. Automated file discovery revealed arbitrary webshell uploads (e.g., `php-reverse-shell.php`) stored within `/opt` and `/tmp`.
- ◆ **SMB Null Sessions & Protocol Risks:** SMBv1 is enabled with null authentication and message signing disabled (`signing: False`), exposing the network to NTLM relay attacks and user enumeration.

Business Impact Assessment

Impact Category	Severity Level	Detailed Risk & Operational Consequences
System Integrity & Administrative Control	Critical	Attackers obtain total root-level rights. Full system access enables execution of unauthorized scripts, wiping system logs (<code>/var/log/auth.log</code> , <code>/var/log/syslog</code>), and creating unauthorized persistent users.
Confidentiality & Data Breach	Critical	Database environments (MySQL 5.0.51a, PostgreSQL 8.3.0) and web applications (<code>phpMyAdmin</code>) are fully accessible. Attackers can exfiltrate sensitive backend data, cleartext configuration files, and system password hashes.
Lateral Movement & Network Pivot	High	With active SMBv1, missing message signing, and full local control, an attacker can utilize this machine as a jump box to launch NTLM relay attacks or attack adjacent internal network segments.

Service Availability & Operational Continuity	High	Attackers can modify, corrupt, or permanently delete core host files, database tables, or system configurations, leading to unrecoverable service downtime.
Regulatory & Compliance Failure	High	Transmission of plain-text passwords over legacy protocols (Telnet, FTP, HTTP), lack of audit logs, and EOL OS software (Ubuntu 8.04, Linux Kernel 2.6.24) violate basic regulatory standards (PCI-DSS, HIPAA, ISO 27001).

Recommended Remediation Plan

Phase 1: Immediate Containment

- ❖ **Isolate System:** Disconnect host 192.168.1.165 from the active network segment or implement strict host firewall rules.
- ❖ **Terminate Legacy Protocols:** Instantly disable Telnet (Port 23), rsh/exec/login services (Ports 512–514), and plain FTP (Port 21). Enforce encrypted transport protocols only.

Phase 2: Account Hardening

- ❖ **Remediate Default Passwords:** Immediately change default system credentials (`msfadmin`) and remove passwordless `sudo` rights.
- ❖ **Disable Anonymous Authentication:** Block anonymous access on FTP and disable SMB Null Sessions.

Phase 3: System Modernization & Infrastructure Hardening

- ❖ **Decommission/Upgrade Legacy OS:** Migrate services off Ubuntu 8.04 / Linux 2.6.24 to a supported Linux distribution.

- ❖ **Harden SMB:** Upgrade to SMBv2/v3, enforce SMB signing, and remove unrestricted WRITE access from public network shares (tmp, opt).
- ❖ **Web Server Security:** Upgrade Apache (2.2.8) and PHP execution engines (5.2.4) to modern versions, disabling PHP CGI argument passing.